

Legitimate Infrastructure Abuse: Auvik / Demio / Zoho

Sanitized one-page case study | Defender for Office 365 + KQL | May 2026

Context

Multiple phishing campaigns were observed abusing legitimate SaaS infrastructure such as Auvik, Demio, Zoho, and Amazon SES. Because the infrastructure itself was legitimate, authentication often fully passed and normal reputation-based filtering became unreliable.

Goal

- Distinguish legitimate SaaS usage from malicious platform abuse.
- Identify stable indicators despite randomized sender/header values.
- Recommend remediation without blocking entire trusted platforms.

Key Actions

- Investigated Auvik invitation abuse using rotating tenant IDs and SES-linked delivery.
- Compared malicious Demio webinar traffic against legitimate webinar workflows.
- Identified repeated use of Demio platform logo in malicious campaigns.
- Validated that legitimate Auvik traffic typically used `envelope.auvik.com` while malicious traffic used different delivery infrastructure.
- Prepared vendor abuse reports with screenshots, phishing samples, and campaign evidence.

Results (sanitized)

- Identified recurring phishing/scam campaigns delivered through trusted SaaS infrastructure.
- Found behavioral indicators more reliable than sender reputation alone.
- Supported targeted remediation and blocking decisions without broad platform blocking.
- Submitted abuse escalation reports directly to affected vendors.

What this shows

I can investigate phishing campaigns operating through legitimate SaaS infrastructure, distinguish abuse from normal platform behavior, and support operational remediation using infrastructure-aware analysis.